

ARHIA v11.1 — Annex Compendium

English technical annexes for trust controls, interoperability and execution readiness

Version: 11.1 (Remediation Release)

Audience: Architecture, CISO, SRE, audit and implementation teams

Classification: Confidential / Controlled use

Change log v11.1: Expanded Annexes K, L, M, N from paragraph summaries to multi-page profiles. Corrected OWASP ASI taxonomy to official December 2025 numbering. Added MAESTRO layer mapping. Added Singapore CSA Addendum citation. Added worked examples, edge cases and failure scenarios throughout. v11.1.1: Added Annexes H (MCP interoperability summary), I (Incident management and escalation), J (Data classification and zoned execution). Expanded Annexes Q (HA topology, replication, failover procedures, DR testing) and R (zone-based cost/risk matrix, Core-M0 sizing, evidence obligations).

Annex A. Landscape crosswalk

This annex provides the detailed crosswalk between ARHIA and the external frameworks it operationalizes. For the summary crosswalk table, see Master Architecture Section 3.

A.1 CSA Agentic Trust Framework alignment

The CSA ATF defines a five-question maturity model with five agent levels (Intern, Junior, Senior, Lead, Executive) and explicit promotion gates. ARHIA's A0–A4 autonomy scale maps as follows: A0 maps to Intern (read-only/suggestion), A1 maps to Junior (recommend with approval), A2 maps to Senior (execute bounded), A3 maps to Lead (autonomous bounded domain), A4 maps to Executive (highest bounded autonomy). ARHIA's promotion gates (evidence, drills, board approval) satisfy the ATF's five promotion requirements (demonstrated accuracy, security audit, measurable impact, clean history, stakeholder approval).

A.2 CSA MAESTRO alignment

MAESTRO (Multi-Agent Environment, Security, Threat, Risk and Outcome) provides a seven-layer reference architecture for agentic AI threat modeling, published by CSA in February 2025. ARHIA maps to MAESTRO layers as follows:

MAESTRO layer	Description	ARHIA mapping
Layer 1: Foundation Models	Core LLMs providing reasoning and generation	Trust Plane: AIBOM validation, model trust checks, zone-based model selection
Layer 2: Data Operations	Data pipelines, storage, vector embeddings	Data classification envelope, zoned execution, egress controls
Layer 3: Agent Frameworks	Orchestration, reasoning loops, tool dispatch	Control Plane: state orchestrator, composition contracts, case management
Layer 4: Deployment Infrastructure	Containers, cloud, network	Zoned deployment model (on-prem, private cloud, external cloud by data class)
Layer 5: Evaluation and Observability	Monitoring, testing, behavioral baselines	Observability Fabric: OpenTelemetry, dashboards, retention, drift detection
Layer 6: Security and Compliance	Access control, privacy, regulatory	Trust Plane: ATK, OPA/Rego policy bundles, capability tokens, audit evidence
Layer 7: Agent Ecosystem	Multi-agent interactions, marketplaces	MCP governance, dual-path interceptor, inter-agent composition contracts, workbench

Annex B. Threat model and OWASP Agentic Top 10 crosswalk

This annex maps the six ARHIA threat actor categories and the official OWASP Top 10 for Agentic Applications (ASI01–ASI10, December 2025) to specific ARHIA mitigations.

B.1 ARHIA threat actors

- Careless insider: an authorized user who makes a mistake that triggers an unintended agent action.
- Malicious insider: an authorized user who deliberately misuses agent capabilities or exfiltrates data.
- External attacker: an unauthorized actor who exploits vulnerabilities in the agent stack from outside the trust perimeter.
- Prompt injection or malicious document: an adversary who embeds malicious instructions in data the agent will process.
- Degraded or out-of-policy capability: a legitimate agent or tool that drifts from its intended behavior due to model degradation, configuration drift or insufficient guardrails.
- Compromised model or dependency supply chain: a malicious or tampered model, plugin, MCP server or dependency that enters the agent ecosystem through the supply chain.

B.2 OWASP Agentic Top 10 (ASI01–ASI10) crosswalk

The following table uses the official OWASP taxonomy published December 10, 2025:

OWASP risk	Description	Primary ARHIA mitigation
ASI01: Agent Goal Hijack	Attackers redirect agent objectives through manipulated instructions, tool outputs or external content	ATK micro-action authorization, OPA/Rego policy bundles, workbench approval gates, no-egress zones for sensitive data, input validation at Trust Plane
ASI02: Tool Misuse and Exploitation	Agents misuse legitimate tools due to prompt injection, misalignment or unsafe delegation	MCP dual-path interceptor with synchronous authorization, tool allowlists, delegated authentication, return-path classification, evidence logging
ASI03: Identity and Privilege Abuse	Attackers exploit inherited/cached credentials, delegated permissions or agent-to-agent trust	IAM integration, ephemeral JWT capability tokens (no persistent sessions), hot token revocation, per-action authorization, delegated auth scoping
ASI04: Agentic Supply Chain Vulnerabilities	Malicious or tampered tools, descriptors, models or agent personas compromise execution	AIBOM validation, model trust checks, signed policy bundles, dependency hash verification, MCP server identity verification

ASI05: Unexpected Code Execution	Agents generate or execute attacker-controlled code	Sandboxed execution zones, code review gates at A2+, capability token scope restrictions, no-code-execution policy for sensitive zones
ASI06: Memory and Context Poisoning	Persistent corruption of agent memory, RAG stores or contextual knowledge	Context declaration rules in composition contracts, shared-context limits, AIBOM checks on knowledge sources, memory integrity validation
ASI07: Insecure Inter-Agent Communication	Spoofed, intercepted or manipulated communication between agents	Composition contracts with identity envelopes, per-handoff re-authorization by ATK, encrypted inter-agent channels, trace continuity verification
ASI08: Cascading Failures	False signals cascade through automated pipelines with escalating impact	Circuit breakers in composition contracts, fallback paths (retry/bypass/rollback/workbench), ATK autonomy degradation under drift, blast-radius containment by zone
ASI09: Human-Agent Trust Exploitation	Confident agent explanations mislead human operators into approving harmful actions	Workbench with curated evidence (not agent-generated summaries), mandatory explanation records with policy_rule_triggered, prior-case comparison, structured decision surfaces
ASI10: Rogue Agents	Misaligned or compromised agents diverge from intended behavior	POST /trust/quarantine-actor, hot token revocation, zero-trust per-action architecture, behavioral drift detection, continuous trust-score monitoring, A0–A4 degradation

Annex C. Multi-agent composition contract

Composition contracts declare the minimum artifacts required for every inter-agent handoff. No handoff proceeds without all six contract elements being satisfied and verified by the ATK.

Contract elements: identity envelope (agent_id, capability_id, tenant, environment, trust level), case context (case_id, trace_id, SLA class, classification ceiling, expected outcome), shared context declaration (what may be shared, what must be masked, retention policy), input/output schema (typed contract for produced and consumed artifacts), fallback path (retry, bypass, rollback or workbench handoff), and evidence expectation (receipts, explanation record, telemetry and ledger pointer).

C.1 Composition patterns

Sequential: Agent A completes, passes output to Agent B. Each handoff is independently authorized. Failure in any step triggers the declared fallback path.

Conditional: Agent A evaluates a condition and routes to Agent B or Agent C. The routing decision is itself an ATK-authorized action.

Parallel: Agents B and C execute simultaneously. A join agent waits for both, reconciles outputs, and produces a merged result. Classification ceiling is the maximum of all parallel branches.

Delegated-with-return: Agent A delegates a subtask to Agent B and waits for the result. Agent B operates under Agent A's case_id but with its own capability token.

Human escalation: Any agent can escalate to the workbench. The human decision is recorded as a governed learning intake event and the trace continues.

Annex D. Formal autonomy scale (A0–A4)

See Master Architecture Section 10 for the summary table. This annex specifies the promotion and degradation mechanics.

D.1 Promotion mechanics

Promotion from level N to N+1 requires: (a) a minimum evaluation period at level N (configurable per capability, default 2 weeks for A0→A1, 4 weeks for A1→A2, 8 weeks for A2→A3, 12 weeks for A3→A4); (b) evidence that promotion gates are satisfied (see Master Architecture Table 9); (c) no unresolved critical policy incidents during the evaluation period; (d) formal approval from the defined authority (capability owner for A0→A2, Architecture Board for A2→A3, Executive sponsor for A3→A4).

D.2 Degradation mechanics

Degradation is automatic and immediate when any of the following triggers fires: drift score exceeds threshold, rollback rate exceeds threshold, critical policy incident detected, AIBOM

trust status changes to untrusted, classification ceiling changes. Degradation always drops to the next lower level. If the agent is at A0, degradation triggers quarantine.

Annex E. Observability Fabric

OpenTelemetry is mandatory for all ARHIA components. Every core component emits traces, metrics and logs. Trace continuity across Trust, Control, Execution, Workbench and MCP is required. See Master Architecture Section 11 for the specification table.

E.1 Minimum dashboard set

- Trust Plane: ATK decision latency (p50/p95/p99), allow/deny/degrade ratios, token issuance rate, AIBOM validation failures, quarantine events.
- Control Plane: case throughput, case age distribution, escalation rate, exception rate, learning intake volume.
- Execution Plane: MCP call success/failure/timeout rates, capability execution latency, zone utilization.
- Workbench: response time (time from escalation to human decision), decision distribution (approve/reject/revise/escalate), SLA compliance rate.
- Drift: drift score by capability, rollback frequency, autonomy level changes over time.

Annex F. Human Workbench contract

The workbench is the bounded decision surface for humans. It presents curated evidence, structured actions and SLA-aware escalation. Humans never see raw payloads; they see explanation records, classification context, expected effects and prior similar cases. See Master Architecture Section 12 for the capability table.

F.1 Workbench SLA

Workbench response time targets are defined per SLA class: Class 1 (critical) = 15 minutes, Class 2 (standard) = 2 hours, Class 3 (batch) = 24 hours. If the SLA is breached, the system can hold (continue waiting), reroute (escalate to a different approver), or emergency fallback (apply the defined fallback path from the composition contract).

Annex G. Governed Learning Loop

The learning loop consumes corrections and incidents, proposes versioned change packages, updates the AIBOM when behavior changes materially, and routes changes through the Architecture Board. It never patches production in place.

G.1 Change package lifecycle

Intake: Human corrections from the workbench, incidents from the exception manager, and regression findings from the testing harness are captured as learning intake events with trace_id, source, classification and proposed change.

Triage: Change proposals are classified by impact (model behavior change, policy change, configuration change) and routed to the appropriate review authority.

Review: The Architecture Board reviews model behavior changes and policy changes. Configuration changes are reviewed by the capability owner.

Staging: Approved changes are deployed to a staging environment and tested against the regression test suite.

Promotion: Changes that pass regression testing are promoted to production in a signed release window. The AIBOM is updated if model behavior changes materially.

Annex H. MCP interoperability profile (summary)

ARHIA adopts MCP as the preferred interoperability protocol for tool use. This annex provides the summary profile; for the full dual-path runtime specification including timing budgets, failure modes, and sequence diagrams, see Annex N.

H.1 MCP governance principles

Every MCP tool call is governed by a capability token issued by the ATK. No MCP call proceeds without prior authorization. The interceptor validates the JWT token (signature, expiration, audience, scope) and enforces a 200ms timing budget for the synchronous authorization path. Return-path classification is mandatory for high-risk capabilities (financial data, PII, credentials). Evidence from every MCP call is recorded asynchronously to the immutable ledger via the event bus.

H.2 MCP server identity and trust

MCP servers are registered in the trust plane with identity, zone assignment, and tool manifests. The JWT audience claim (aud) must match the registered MCP server identity. Unregistered MCP servers are blocked by default. Tool manifests declare input/output schemas and classification ceilings for return-path validation.

Annex I. Incident management and escalation profile

This annex defines the incident management lifecycle for ARHIA-governed systems, from detection through resolution and post-incident review.

I.1 Incident severity classification

Critical: AIBOM supply-chain compromise, quarantine event, data exfiltration detected, or ledger integrity failure. Response: immediate quarantine of affected actors, hot token revocation, incident commander assigned within 15 minutes, CISO notified. High: repeated policy denials from a single actor, drift score sustained above threshold, MCP interceptor timeout spike, or workbench SLA breach. Response: autonomy degradation, workbench triage within 1 hour. Medium: AIBOM approaching staleness for multiple models, elevated exception rate, single policy incident without data impact. Response: scheduled review within 24 hours, governed learning intake. Low: telemetry degradation, non-critical dashboard alert, configuration drift. Response: next business day review, ops ticket.

I.2 Escalation matrix

Level 1 (SRE/operations): automated alert triage, initial containment, workbench operator. Level 2 (ARHIA architect + capability owner): policy review, root cause analysis, change package proposal. Level 3 (CISO + Architecture Board): critical incidents, quarantine review, post-incident governance decisions. Level 4 (executive sponsor): incidents with regulatory, reputational, or material financial impact. All escalations are recorded in the immutable ledger with trace_id continuity.

I.3 Post-incident review

Every critical and high incident triggers a post-incident review within 5 business days. The review produces: root cause analysis, timeline reconstruction from the immutable ledger, policy and control gaps identified, remediation actions with owners and deadlines, and governed learning intake entries. Review findings feed the Governed Learning Loop (Annex G) and may trigger policy bundle updates, AIBOM re-validation, or autonomy level adjustments.

Annex J. Data classification and zoned execution profile

This annex specifies the data classification scheme and zone execution rules referenced throughout the architecture. Data sensitivity determines where capabilities may execute, what model types may be used, and whether egress is permitted.

J.1 Classification levels

Level 1 (Public): non-sensitive, publishable data. Any zone, any model. Level 2 (Internal): internal business data, no PII. Zones 1–3, local or external models with masked egress. Level 3 (Confidential): PII, financial records, HR data. Zones 1–2 only, local models preferred, external models require masking and workbench approval at A2+. Level 4 (Restricted): regulated data (health, legal privilege, trade secrets). Zone 1 only, local models only, no external egress, mandatory human approval. Level 5 (Critical): national security, critical infrastructure. Zone 1 only, air-gapped, dedicated hardware, A0–A1 only.

J.2 Zone definitions

Zone 1 (Trusted on-premises): enterprise data center, air-gapped or private network. All classification levels permitted. Local SLM/LLM inference only. Zone 2 (Private cloud): regulated VPC with encryption at rest and in transit. Classification 1–3 permitted. Local or private-hosted models. Masked egress for classification 3. Zone 3 (External cloud): public cloud with tenant isolation. Classification 1–2 only. External frontier models permitted for classification 1–2. No PII egress. Zone 4 (Edge/partner): partner-hosted environments. Classification 1 only. Read-only agent capabilities.

J.3 Egress rules

Egress from higher to lower trust zones requires: data masking or anonymization for PII, classification downgrade verification by the MCP interceptor return-path classifier, explicit egress authorization in the capability token scope, and evidence recording in the immutable ledger. No-egress zones (classification 4–5) block all outbound data transfer to external zones. The MCP interceptor enforces egress rules at the protocol level, not just at the policy level.

Annex K. AIBOM profile and model supply-chain assurance

The AI Bill of Materials (AIBOM) is the trust artifact that the ATK validates before allowing a model to participate in high-risk execution. This annex specifies the minimum AIBOM schema, the validation logic, and worked examples.

K.1 Minimum AIBOM fields

Field	Type	Description	Example
model_id	string	Unique identifier for the model version	gpt-4o-2025-03-01
publisher	string	Organization that published the model	OpenAI
provenance	string	Origin and training data lineage	Trained on proprietary dataset v3.2
license	string	License under which the model is used	commercial-api
hash	string	SHA-256 hash of model weights or API version fingerprint	sha256:a1b2c3d4...
signature_status	enum	verified unverified expired revoked	verified
runtime_version	string	Runtime/SDK version used to execute the model	openai-sdk-1.12.0
dependency_chain	array	List of critical dependencies with versions	[{"name": "tiktoken", "version": "0.7.0"}]
zone_allowance	array	Zones where this model is permitted to execute	["1", "2"]
approval_status	enum	approved conditional pending rejected	approved
last_validated	ISO 8601	Timestamp of most recent validation	2026-03-15T00:00:00Z
risk_classification	integer	Data classification ceiling for this model (1–5)	2

K.2 ATK AIBOM validation logic

Before any high-risk execution (classification ≥ 3 or autonomy $\geq A2$), the ATK performs the following checks in order: (1) Retrieve the AIBOM for the model_id specified in the policy/supply chain envelope. (2) Verify signature_status is “verified.” If expired or revoked, deny. (3) Verify hash matches the expected hash for the model version. If mismatch, quarantine the actor and log a supply-chain incident. (4) Verify zone_allowance includes the requested execution zone. If not, deny. (5) Verify approval_status is “approved” or “conditional.” If pending or rejected, deny. (6) Verify risk_classification is $\geq$ the data classification ceiling in the request. If insufficient,

deny. (7) Verify last_validated is within the configured staleness threshold (default: 30 days). If stale, allow_with_restrictions (reduced TTL, mandatory re-validation before next action).

K.3 Worked example: AIBOM rejection

Scenario: A payroll agent requests execution of a salary calculation using model “local-slm-v2.” The AIBOM for local-slm-v2 shows zone_allowance: ["1"] but the payroll capability requires zone 2 execution because it processes PII. The ATK evaluates: zone_allowance check fails (zone 2 not in ["1"]). Decision: deny. Reason code: ZONE_NOT_ALLOWED. Explanation record: “Model local-slm-v2 is not approved for zone 2 execution. Zone 2 is required because the payroll-salary-calc capability processes PII (classification 3).” The deny decision is recorded in the immutable ledger with trace_id, actor_id, capability_id, reason code and explanation record.

K.4 Worked example: AIBOM hash mismatch (supply-chain compromise)

Scenario: An agent requests execution using model “frontier-llm-v5.” The AIBOM shows hash: sha256:abc123 but the runtime reports hash: sha256:def456. The ATK evaluates: hash mismatch detected. Decision: quarantine_actor. Action: immediate token revocation for all tokens issued to this actor in the current session. Incident record created with severity: critical. Explanation record: “Model hash mismatch detected for frontier-llm-v5. Expected sha256:abc123, received sha256:def456. Possible supply-chain compromise. Actor quarantined pending investigation.”

Annex L. Explanation record / XAI profile

Each material decision by the ATK produces an explanation record that is both machine-readable and human-readable. This annex specifies the schema, storage requirements and worked examples.

L.1 Explanation record schema

Field	Type	Description
explanation_id	UUID	Unique identifier for this explanation record
trace_id	string	Trace ID linking this record to the full execution trace
decision	enum	allow allow_with_restrictions require_human_approval deny degrade_autonomy quarantine_actor
reason_code	string	Machine-readable reason code (e.g., ZONE_NOT_ALLOWED, AIBOM_HASH_MISMATCH, POLICY_DENY_HIGH_CLASSIFICATION)
policy_rule_triggered	string	OPA/Rego rule path that produced the decision (e.g., arhia.authz.allow)
effective_autonomy	string	Autonomy level applied after any degradation (e.g., A2 → A1)
classification_ceiling	integer	Data classification ceiling for this action
zone	string	Execution zone assigned
trust_signals	object	Drift score, AIBOM status, trust score, prior incident count
human_readable_rationale	string	Natural language explanation suitable for workbench display
timestamp	ISO 8601	When the decision was made

L.2 Worked example: explanation record for allow_with_restrictions

Scenario: A customer-onboarding agent at A2 requests to send a welcome email (classification 1, zone 2). The AIBOM for the email model is valid but last_validated is 25 days old (threshold: 30 days). The ATK allows with restrictions. Explanation record: decision: allow_with_restrictions. reason_code: AIBOM_APPROACHING_STALENESS. policy_rule_triggered: arhia.authz.staleness_check. effective_autonomy: A2 (unchanged). classification_ceiling: 1. zone: 2. trust_signals: {drift_score: 0.02, aibom_status: verified, aibom_age_days: 25, trust_score: 0.91}. human_readable_rationale: "Action allowed with reduced TTL (60s instead of 120s) because the AIBOM for email-composer-v3 is approaching its staleness threshold (25/30 days). Re-validation recommended before next session."

Annex M. OPA/Rego policy bundle profile and test harness

OPA/Rego is the mandatory Policy-as-Code standard. The ATK submits a canonical JSON input; bundles are versioned, tested and promoted through signed release windows.

M.1 Canonical ATK input schema

The ATK submits the following JSON structure to the OPA decision endpoint for every evaluation:

```
{ "actor_id": "agent-payroll-01", "capability_id": "payroll-batch-create", "tenant": "acme-corp",
  "environment": "production", "classification": 3, "max_class_allowed": 3, "zone": 2,
  "zone_allowed": true, "autonomy_level": 2, "max_autonomy_allowed": 2, "aibom_trusted": true,
  "aibom_hash_valid": true, "drift_score": 0.03, "drift_threshold": 0.10, "trace_id": "trace-2026-03-15-001", "policy_bundle_version": "v2.1.0" }
```

M.2 Policy bundle structure

Each policy bundle is a directory containing: (a) `authz.rego` — the main authorization policy; (b) `zone.rego` — zone-specific rules; (c) `autonomy.rego` — autonomy level governance; (d) `aibom.rego` — AIBOM validation rules; (e) `data.json` — static data (zone definitions, classification mappings, capability registrations); (f) `test/` directory with OPA test files. Bundles are signed with SHA-256 and version-tagged. Promotion follows: `develop` → `test` → `staging` → `production`, with mandatory test pass at each gate.

M.3 Sample policy: `authz.rego` (expanded)

```
package arhia.authz
default allow = false
default decision = "deny"
allow if {
  input.zone_allowed == true
  input.classification <= input.max_class_allowed
  input.autonomy_level <= input.max_autonomy_allowed
  input.aibom_trusted == true
  input.aibom_hash_valid == true
  input.drift_score <= input.drift_threshold
}
decision = "allow" if { allow }
decision = "degrade_autonomy" if { not allow; input.drift_score > input.drift_threshold;
input.aibom_trusted == true }
decision = "deny" if { not allow; input.aibom_trusted == false }
```

M.4 Test harness

OPA test files follow the pattern `test_<rule>_<scenario>.rego`. Minimum test cases required before bundle promotion: (1) `test_allow_happy_path` — all conditions met, expect allow. (2) `test_deny_zone_not_allowed` — `zone_allowed` false, expect deny. (3) `test_deny_classification_exceeded` — `classification` > `max`, expect deny. (4) `test_deny_aibom_untrusted` — `aibom_trusted` false, expect deny. (5) `test_degrade_drift_exceeded` — drift above threshold with trusted AIBOM, expect `degrade_autonomy`. (6) `test_deny_hash_invalid` — `aibom_hash_valid` false, expect deny.

Annex N. MCP dual-path runtime profile

ARHIA adopts MCP as the preferred interoperability protocol for tool use. The interceptor operates in dual path: synchronous for authorization and high-risk return-path checks, asynchronous for extended analytics and evidence. This annex specifies the dual-path mechanics, timing budget and failure modes.

N.1 Synchronous path (authorization and high-risk return)

The synchronous path is invoked for every MCP tool call. The sequence is: (1) Agent issues MCP call with capability token. (2) MCP interceptor validates the capability token (signature, expiration, audience, scope). (3) If token is valid, interceptor forwards the call to the target MCP server. (4) Target MCP server returns the result. (5) If the capability is flagged as high-risk-return (e.g., financial data, PII, credentials), the interceptor classifies the return payload before forwarding to the agent. (6) If the return classification exceeds the agent's classification ceiling, the return is masked or blocked and the event is logged.

N.2 Asynchronous path (analytics and evidence)

The asynchronous path is invoked after the synchronous path completes. It does not block the agent. The sequence is: (1) The interceptor emits an evidence event to the event bus containing: trace_id, tool name, input hash, output classification, latency, outcome (success/failure/timeout). (2) The evidence enrichment service consumes the event and correlates it with the ATK decision record and the ledger entry. (3) The enriched evidence is written to the immutable ledger.

N.3 Timing budget

The synchronous path has a total budget of 200ms. Token validation: 10ms. Network round-trip to MCP server: 150ms. Return-path classification (if applicable): 40ms. If the budget is exceeded, the interceptor logs a timeout event and applies the configured timeout policy: for critical capabilities, deny and route to workbench; for non-critical capabilities, allow with reduced TTL on next action.

N.4 Failure modes

MCP server unreachable: Interceptor returns a structured error to the agent. The composition contract's fallback path is activated (retry, bypass, rollback or workbench handoff). Event logged.

Token expired mid-call: Interceptor rejects the call. Agent must re-request authorization from the ATK. If the capability is idempotent, the agent can retry with a new token.

Return-path classification failure: If the classification service is unavailable, the interceptor blocks the return for high-risk capabilities and logs a degraded-path event. For low-risk capabilities, the return is forwarded with a warning.

Annex O. ATK reference implementation contract

This annex specifies the API surface of the ATK as implemented in the reference FastAPI service. See the ATK Reference Implementation Pack v2.0 for the runnable code.

O.1 Reference endpoints

Endpoint	Method	Description	Returns
POST /trust/evaluate-action	POST	Evaluate a micro-action against policy, AIBOM and trust state	Decision (allow/deny/degrade/etc.), explanation record, capability token if approved
POST /trust/revoke-token	POST	Revoke an active capability token	Confirmation with revocation timestamp
POST /trust/quarantine-actor	POST	Quarantine an actor: revoke all tokens, block new requests	Quarantine record with incident_id
POST /trust/degrade-autonomy	POST	Reduce an actor's effective autonomy level	New effective level, explanation record
GET /trust/decision/{trace_id}	GET	Retrieve the decision record for a trace_id	Decision record with explanation and ledger pointer
GET /health	GET	Health check for the ATK service	Status, OPA connectivity, AIBOM cache age

Annex P. First enterprise pilot playbook

See the separate Enterprise Pilot Playbook v2.0 document for the fully operationalized playbook with RACI, week-by-week timeline, drill scripts, go/no-go decision matrix and evidence templates.

Annex Q. High availability, disaster recovery, RPO / RTO profile

RTO/RPO expectations by component:

Component	RTO target	RPO target	Rationale
Trust Plane (ATK)	< 5 minutes	0 (no data loss)	Trust decisions must resume immediately; deny-by-default during outage
Control Plane	< 15 minutes	< 1 minute	Case state is persistent; replay from queue after recovery

Immutable Ledger	< 30 minutes	0 (no data loss)	Ledger is append-only and replicated; no entries may be lost
Observability stack	< 1 hour	< 5 minutes	Telemetry can be buffered and replayed; some delay is acceptable

Q.1 Deployment topology for high availability

The Trust Plane (ATK, OPA, token issuer) is deployed as a stateless service cluster behind a load balancer with a minimum of three replicas across two availability zones. Policy bundles and AIBOM cache are pre-warmed on startup from a shared configuration store (Consul, etcd, or cloud-native equivalent). The active_tokens and quarantined_actors state is backed by a replicated in-memory store (Redis Sentinel or equivalent) to survive individual pod failures without losing runtime state. The OPA sidecar is co-located with each ATK instance and serves the signed policy bundle from local cache, with a 40ms SLA for evaluation.

Q.2 Ledger replication strategy

The immutable ledger is the most critical persistence layer (RPO = 0). In production, it is backed by a synchronously replicated database (PostgreSQL with synchronous replication, or a cloud-managed equivalent such as Aurora or Cloud SQL with multi-AZ). Each ledger entry includes a hash-chain reference and an HMAC signature computed with a key stored in a hardware security module (HSM) or cloud KMS. The HMAC key is separate from the JWT signing key. Backup strategy: continuous WAL archiving to a separate storage account with point-in-time recovery capability. Retention: per legal and regulatory schedule, minimum 7 years for financial services.

Q.3 Failover procedure

Trust Plane failure: load balancer health checks detect unresponsive ATK instances and route traffic to healthy replicas. If all replicas in a zone fail, deny-by-default is enforced for critical actions; non-critical actions may use a short-TTL safe cache (maximum 30 seconds, low-risk repeats only). The Control Plane enters hold-and-review mode, queuing new cases until Trust Plane is restored. Recovery steps: (1) automated restart of ATK pods, (2) AIBOM cache warm-up from configuration store (target: 60 seconds), (3) OPA bundle synchronization, (4) health check passes, (5) traffic restored. Ledger failure: all planes halt writes and enter read-only mode. No new decisions are issued until ledger writes are confirmed. This is the only component where availability is sacrificed for integrity. Observability failure: critical actions continue if trust and evidence minimums still hold; non-critical actions enter hold-and-review.

Q.4 DR testing cadence

Failover drills are executed quarterly. The pilot playbook (Annex P) includes two rollback drills during the 10-week pilot. Post-pilot, the minimum DR testing cadence is: Trust Plane failover

drill quarterly, ledger integrity verification daily (automated), full disaster recovery simulation annually (including cross-region failover if applicable).

Annex R. Procurement and cost support artifacts

This annex provides procurement teams with cost estimation guidance for ARHIA deployments. See Master Architecture Section 15 for the cost driver table.

R.1 Zone-based cost/risk matrix

Zone 1 (on-premises): highest infrastructure cost, lowest risk exposure. Typical drivers: GPU/CPU hardware, physical security, dedicated operations staff. Zone 2 (private cloud): moderate cost, moderate risk. Typical drivers: cloud compute reserved instances, managed database, private networking, compliance certifications. Zone 3 (external cloud): lowest infrastructure cost, highest risk exposure. Typical drivers: API token costs for frontier models, egress bandwidth, masking/anonymization services. The cost/risk tradeoff determines the optimal zone mix for a given deployment: high-sensitivity use cases justify the cost premium of Zone 1; high-volume low-sensitivity use cases benefit from the cost efficiency of Zone 3.

R.2 Core-M0 sizing worksheet

Core-M0 is the minimum contractual scope for a first regulated go-live. The sizing worksheet covers: Trust Plane infrastructure (3 ATK instances, OPA sidecars, Redis for token state, PostgreSQL for ledger), Control Plane infrastructure (event bus, case database, workflow engine), Execution Plane baseline (MCP interceptor deployment, agent runtime), Observability stack (OpenTelemetry collector, Grafana/Prometheus or cloud equivalent, log aggregation), and Workbench (web application, notification service). The typical Core-M0 infrastructure cost range for a single-zone private cloud deployment with 1–3 capabilities is USD 8,000–15,000/month, excluding licensing, professional services, and model inference costs. A supplementary Excel-based sizing calculator is available from the implementation team.

R.3 Minimum evidence obligations for procurement

Procurement contracts for ARHIA implementations should require the following minimum evidence: a completed pilot evidence package per Annex P / Enterprise Pilot Playbook v2.0, a go/no-go scorecard with a minimum score of 85 points, verified ledger integrity for the pilot period, all critical policy incidents resolved, and a signed Core-M0 deployment plan with RACI, timeline, and SLA commitments. These evidence obligations ensure that procurement decisions are based on demonstrated operational readiness, not projected capabilities.

End of ARHIA v11.1 Annex Compendium.